Portal Microsoft Roadmap

For David · Proposed architecture for review, not a completed security assessment. The existing GPT Sites export and tenant configuration have not yet been inspected.

GitHub (owned source) → **Vercel** (Next.js / React / TypeScript app + server API)
Microsoft Entra ID → **Supabase Auth** → **PostgreSQL + private Storage**

01 Microsoft identity & access

Single-tenant Entra app registration, tenant-specific Supabase Azure provider, exact callback allowlist, and PKCE app sign-in. Require assigned staff; exclude unapproved guests and personal accounts. Configure the recommended xms_edov claim and avoid email-domain-only authorization. [1, 2]

David owns consent, MFA and Conditional Access policy (subject to licensing). Use trusted identity IDs and application-controlled roles. Microsoft sign-in does not grant mailbox, calendar, or document access.

02 Data boundaries & offboarding

Enforce active membership and record-level permissions at the API and database using row-level security. Use private file access, server-only privileged secrets, input validation, and redacted logs. Test denied access as well as successful access. [3]

Entra account disablement alone does not immediately invalidate an existing Supabase session. Include a portal-disable/revoke runbook and live membership checks; agree and test session expiry and the offboarding window with IT. [4]

03 Operations & recovery

TPLG owns service accounts and the repository. Separate test/live environments; use non-sensitive pilot data first. Agree regions, retention, service plans, and incident ownership. Keep schema migrations, review deployments, and test restore/rollback. Database backups do not include stored file contents; arrange file recovery separately. [5]

04 Microsoft Teams & permissions

Base beta: a portal link accessible from Teams. An embedded tab, Teams SSO, bot, or activity feed requires separate Teams app configuration, tenant approval, and desktop/mobile testing. Teams SSO and Graph consent are separate concerns. [6]

Optional agent: start with delegated, read-only access to approved email/calendar sources. Request only the selected workflow's Graph scopes. Unattended application permissions need separate justification and admin consent; no tenant-wide mailbox access by default. [7]

05 Agent pilot controls

One workflow, up to two approved source integrations, and the portal. Propose tasks first; a person approves writes. Restrict tools and record access, retain source references, prevent duplicates, log actions, bound retries, and provide a pause control. Treat email/document instructions as untrusted content. [8]

IT approves the model provider, data sent to it, retention, and any subprocessors. No email sending, payments, deletions, or autonomous external actions in this pilot.

06 Decisions & acceptance

Confirm export/reuse, pilot users and roles, sensitive data, region/retention, notification sender, service plans, and IT ownership before kickoff. Test sign-in, denied access, offboarding, saves and concurrent edits, notifications, mobile, and recovery. Release to pilot users only after blocking issues are resolved.

Next step: Review the proposed architecture with David and confirm tenant requirements, data boundaries, and pilot acceptance checks. Microsoft-only infrastructure or additional controls can be discussed before implementation.

Official references (click to open): 1 Microsoft auth · 2 Entra assignment · 3 RLS · 4 Sessions · 5 Backups · 6 Teams SSO · 7 Graph consent · 8 Agent safety